Corporate VPN, GitHub Enterprise Access & Cybersecurity Compliance Manual

Effective Date: January 1, 2026 • Owner: Enterprise Identity, Network Security & Governance • Classification: Internal Use

Section 1. Corporate VPN Configuration and Zero-Trust Network Access

Access to internal corporate networks (`*.ibm.internal`), staging clusters, Artifactory mirrors, and internal GitHub Enterprise servers from outside a physical campus office requires an active, authenticated session through the **Cisco Secure Client (formerly AnyConnect) with Zero-Trust Posture Check**.

1.1 Regional VPN Gateway Profiles and Connection Procedure

Launch the Cisco Secure Client application from your system tray and select the regional gateway corresponding to your physical location to minimize latency:

- **Americas East Gateway:** `vpn-us-east.ibm.internal` (Primary for Raleigh, New York, Toronto, Atlanta)
- **Americas West Gateway:** `vpn-us-west.ibm.internal` (Primary for San Jose, Austin, Seattle)
- **EMEA Central Gateway:** `vpn-emea.ibm.internal` (Primary for Bucharest, London, Frankfurt, Dublin, Zurich)
- **APAC Gateway:** `vpn-apac.ibm.internal` (Primary for Tokyo, Singapore, Bengaluru, Sydney)

To authenticate, enter your corporate W3 intranet email address, your 20-character W3 SSO passphrase, and complete the FIDO2/WebAuthn prompt using either your registered **YubiKey 5 FIPS Hardware Token** or the **IBM Security Verify Push** notification on your enrolled mobile device. SMS-based one-time passcodes are disabled for VPN authentication due to SIM-swapping security risks.

1.2 VPN Session Timeouts and Split-Tunnel Policy

- **Maximum Continuous VPN Session Duration:** Every VPN session enforces a hard re-authentication timeout of **12 consecutive hours (720 minutes)** and an idle inactivity disconnect timeout of **30 minutes**.
- **Split-Tunnel vs. Full-Tunnel Routing:** Standard employee profiles use **Split-Tunnel mode** (`Profile: IBM-Standard-Split`), routing only corporate CIDR subnets (`10.0.0.0/8`, `172.16.0.0/12`, and `*.ibm.internal`) through the encrypted tunnel while allowing high-bandwidth video calls to egress directly. Engineers accessing production database jump-hosts or handling Restricted Class-4 data must switch to the **Full-Tunnel Profile (`Profile: IBM-Prod-FullTunnel`)**, which routes 100% of workstation traffic through the corporate Cloud Access Security Broker (CASB).

- **Resolving VPN Posture Failure `ERR-POSTURE-403`:** If VPN connection fails with `ERR-POSTURE-403 (Host Scan Non-Compliant)`, open the Endpoint Self-Service agent and click **Run Compliance Remediation**. This error occurs when OS security patches are more than **14 calendar days overdue** or the CrowdStrike Falcon sensor has been stopped.

Section 2. GitHub Enterprise (`github.ibm.internal`) Access & Key Management

> **GitHub Access Request Quick Reference:** To gain write or maintainer access to an internal GitHub Enterprise organization (`https://github.ibm.internal`), submit an access request in the **AccessHub IAM Portal (`w3.ibm.internal/accesshub`)** specifying Entitlement Code **`GHE-ENG-CONTRIB`** and the target GitHub Organization name. Approval is required from two people: (1) your **First-Line Manager** and (2) the **GitHub Organization Owner**. Provisioning completes automatically within **2 hours** of final approval. All commits must be cryptographically signed using an **Ed25519 SSH key or GPG key**, and Personal Access Tokens (PATs) must be set to expire in **90 days or less**.

2.1 Step-by-Step Procedure to Request GitHub Enterprise Access

1. Ensure you have completed the mandatory course **`SEC-104: Secure Source Code & Open Source Governance`** in the YourLearning portal; AccessHub automatically blocks GitHub entitlement requests if `SEC-104` is incomplete.
2. Navigate to `https://w3.ibm.internal/accesshub` and select **Request New Entitlement > Source Control > GitHub Enterprise (`github.ibm.internal`)**.
3. Select the appropriate role entitlement:
   • `GHE-READ-ONLY` — Read/Clone access to internal public repositories (Auto-approved).
   • `GHE-ENG-CONTRIB` — Write/Branch/Pull-Request access for engineering squad members (Requires First-Line Manager + GitHub Org Owner approval).
   • `GHE-REPO-ADMIN` — Repository creation and branch-protection administration (Requires Second-Line Manager + Security Champion approval; reviewed quarterly).
4. Once approved, log in to `https://github.ibm.internal` via W3 Single Sign-On to initialize your profile.

2.2 Mandatory Ed25519 SSH Key Generation and Signed Commits

Password authentication over HTTPS to `github.ibm.internal` is permanently disabled. Furthermore, all repositories enforce the **Verified Commit Signature Policy**: unsigned commits are rejected by the server pre-receive hook. Generate a dedicated `ed25519` SSH key for authentication and commit signing:

```
# 1. Generate a passphrase-protected Ed25519 SSH key (RSA keys < 4096 bits are
rejected):
ssh-keygen -t ed25519 -C "your.name@ibm.com" -f ~/.ssh/id_ed25519_ghe

# 2. Add the key to your OS keychain agent:
ssh-add --apple-use-keychain ~/.ssh/id_ed25519_ghe

# 3. Upload ~/.ssh/id_ed25519_ghe.pub to https://github.ibm.internal/settings/keys
#    as BOTH an "Authentication Key" and a "Signing Key".

# 4. Configure Git globally to sign every commit with your SSH key:
git config --global gpg.format ssh
git config --global user.signingkey ~/.ssh/id_ed25519_ghe.pub
git config --global commit.gpgsign true
git config --global tag.gpgsign true
```

2.3 Branch Protection and Personal Access Token (PAT) Expiration Rules

- **Protected Branch Enforcement (`main` / `release/*`):** Direct pushes and force-pushes to `main` or `release/*` branches are blocked across all organizations. Every merge requires a Pull Request with: (1) at least **1 peer code review approval** (or **2 approvals** for production Tier-1 services), (2) passing CI unit test and Travis/Tekton pipeline checks, (3) zero Critical or High CVEs flagged by Snyk/Mend, and (4) verified commit signatures.
- **Personal Access Token (PAT) Rotation Policy:** Fine-grained PATs created for CLI automation or local scripts may have a maximum lifetime of **90 calendar days**. Tokens configured with "No Expiration" are automatically revoked by the CISO nightly scanner at `02:00 UTC`.

Section 3. Mandatory Cybersecurity Compliance Training & Deadlines

Every employee, contractor, and intern must complete mandatory cybersecurity, data privacy, and AI ethics training modules via the **YourLearning Compliance Portal (`w3.ibm.internal/yourlearning`)**.

3.1 New-Hire Onboarding Compliance Deadlines (First 30 Days)

New hires must complete the following four foundational modules within **30 calendar days** of their start date:

- **`SEC-101: Annual Cybersecurity & Phishing Defense Fundamentals`** (Duration: 45 minutes; minimum passing quiz score: **85%**).
- **`PRIV-201: Global Data Privacy, GDPR & PII Handling`** (Duration: 30 minutes; minimum passing quiz score: **80%**).
- **`AI-GOV-105: Responsible AI, Generative AI Guardrails & Client Data Confidentiality`** (Duration: 40 minutes; required before using watsonx or any LLM tool).
- **`BCG-001: Business Conduct Guidelines & Annual Ethics Certification`** (Duration: 60 minutes; requires electronic signature).

3.2 Annual Recertification Deadline and Automated Account Suspension Policy

For all active employees, annual recertification of `SEC-101`, `PRIV-201`, and `BCG-001` opens on September 1 each year and must be completed no later than **October 31 at 23:59 UTC**.

- **Grace Period (November 1 to November 7):** Employees who miss the October 31 deadline receive daily automated escalation emails copied to their First-Line and Second-Line Managers.
- **Automated Network & VPN Suspension (Day 8 Overdue — November 8):** If mandatory compliance training remains incomplete more than **7 calendar days past the deadline** (or past day 30 for new hires), the Identity Governance engine automatically places a **Compliance Hold (`HOLD-SEC-TRAIN`)** on the employee's account, suspending VPN access, GitHub Enterprise pushes, and cloud console privileges until the training is completed in YourLearning (access restores automatically within **45 minutes** of course completion).

Section 4. Corporate Data Classification and Public AI Usage Rules

All corporate documents, databases, and source code are classified into four sensitivity tiers:

1. **Level 1 — Public (`L1-PUBLIC`):** Marketing collateral, published press releases, and open-source documentation approved for external release.
2. **Level 2 — Internal Use Only (`L2-INTERNAL`):** General internal wikis, org charts, standard operating procedures, and non-sensitive internal technical guides.
3. **Level 3 — Confidential (`L3-CONFIDENTIAL`):** Proprietary source code, internal architecture roadmaps, employee HR records, unreleased financial figures, and customer metadata. Must be encrypted in transit (TLS 1.3) and at rest (AES-256).
4. **Level 4 — Restricted / Crown Jewels (`L4-RESTRICTED`):** Customer production database payloads, personally identifiable healthcare/financial records (PHI/PCI), cryptographic master keys, and M&A strategy files.

Strict Prohibition on Public Consumer LLMs: Employees are strictly forbidden from pasting, uploading, or transmitting any `L2-INTERNAL`, `L3-CONFIDENTIAL`, or `L4-RESTRICTED` text, source code, or PDF documents into public consumer AI tools (such as public ChatGPT, public Claude, or unapproved browser extensions). All internal document search, summarization, and RAG workflows must run exclusively on approved internal infrastructure such as **DocuSense AI backed by IBM Db2 and internal watsonx instances**.